AEGISAI ENTERPRISE EDITION

SUITE DE DOCUMENTACIÓN TÉCNICA

Manual de Seguridad, Operaciones y Defensa OWASP LLM Top 10

Endurecimiento Zero-Trust, Alertamiento C12.2 y Mitigación de Inyecciones C02.10

Versión de Plataforma:	**2.5.0 Enterprise Edition**
Alcance Normativo:	**OWASP AISVS v1.0, ISO/IEC 42001:2023, Google Cloud Security**
Licencia:	**Apache License 2.0 (Open Source)**

Equipo de Ingeniería AegisAI

Clasificación: Público / Open Source

AEGIS AI ASSURANCE PLATFORM

Manual de Administración y Operación (DevSecOps Guide)

Versión: 2.5.0 Enterprise (Edición 2026)

Clasificación: Guía Técnica Operativa / Uso General

Alcance: Gobierno de Plataforma, Gestión de Claves, Observabilidad y Operación

1. Perfil y Responsabilidades del Administrador

El Administrador de AegisAI es responsable de:

1. Custodiar y rotar las credenciales maestras del sistema (`ADMIN_API_TOKEN` y `GEMINI_API_KEY`).
2. Supervisar la cuota, latencia y telemetría de inferencia de la API de Google Gemini.
3. Administrar el catálogo de marcos normativos personalizados (módulo BYOF) y autorizar la publicación o baja de normativas organizacionales.
4. Mantener la integridad y disponibilidad de la capa de almacenamiento dual (archivos locales JSON y base de datos Cloud Firestore).
5. Atender incidencias operativas y garantizar el cumplimiento de los Acuerdos de Nivel de Servicio (SLA).

2. Gestión de Identidad y Control de Acceso

2.1 Esquema de Autenticación en Capas

AegisAI implementa tres mecanismos complementarios de autenticación:

Nivel de Acceso	Mecanismo	Variable / Cabecera	Alcance Operativo
Administración Web	Token Secreto en sesión	Cabecera `x-admin-token`	Acceso a `/api/admin/settings`, `/api/admin/test-connection` y eliminación de marcos.
Automatización CI/CD	API Key de Servicio	Cabecera `x-api-key`	Invocación de auditorías asíncronas vía `/api/v1/audits` desde GitHub Actions o GitLab CI.
Operador Local	Sesión de Emergencia	Token de bootstrap	Acceso a la interfaz de usuario en modo autónomo cuando Firebase Auth no está disponible.

2.2 Middleware de Autenticación Administrativa en Tiempo Constante (`C05.3`)

El endpoint `/api/admin/*` está protegido por el middleware `authenticateAdmin` en `server.ts` utilizando `crypto.timingSafeEqual` sobre digests SHA-256 para erradicar ataques laterales de temporización (*timing attacks*):

```
function timingSafeTokenMatch(provided: string | null | undefined, configured: string | null | undef
  if (!provided || !configured) return false;
  const hashProvided = crypto.createHash('sha256').update(String(provided), 'utf8').digest();
  const hashConfigured = crypto.createHash('sha256').update(String(configured), 'utf8').digest();
  return crypto.timingSafeEqual(hashProvided, hashConfigured) && provided.length === configured.leng
}

const authenticateAdmin = (req: express.Request, res: express.Response, next: express.NextFunction)
  const configuredToken = process.env.ADMIN_API_TOKEN;
  const providedToken = (req.headers['x-admin-token'] as string) ||
    (req.headers.authorization?.startsWith('Bearer ') ? req.headers.authorization.split(' ')[1] : nu

  if (timingSafeTokenMatch(providedToken, configuredToken)) {
    return next();
  }
  return res.status(401).json({ error: 'Acceso no autorizado: Token de administración inválido o aus
};
```

3. Configuración y Monitoreo del Motor de Inteligencia Artificial Multimodelo

3.1 Soporte Multi-Proveedor Desacoplado

AegisAI cuenta con un motor universal desacoplado de inferencia que permite operar tanto con modelos de Google Gemini como con proveedores y enrutadores externos compatibles con la especificación OpenAI (`/v1/chat/completions`):

- **Google Gemini:** Modelos nativos (`gemini-3.8-flash` , `gemini-3.1-flash-lite` , `gemini-3.5-pro`) vía `@google/genai` SDK con tolerancia a picos de demanda.
- **OpenRouter (Router Universal):** Enrutamiento centralizado hacia Claude 3.7 Sonnet, GPT-4o, DeepSeek R1, Llama 3.3 70B, etc., con cabeceras `HTTP-Referer` y `X-Title` .
- **OpenAI Directo:** Modelos insignia de OpenAI (`gpt-4o` , `gpt-4o-mini` , `o1` , `o3-mini`).
- **Local / Proxy Universal (OpenAI-Compatible):** Para inferencia privada on-premise mediante **vLLM**, **Ollama**, **LiteLLM**, **OpenWebUI** o **LM Studio**.

3.2 Variables de Entorno y Configuración por Archivo

En el archivo `.env` o en `config/admin-settings.json` se parametrizan las opciones del motor:

```
# Clave de API de Google Gemini (requerida si se usa proveedor Gemini)
GEMINI_API_KEY="AIzaSy..."

# Token maestro administrativo para el panel de configuración
ADMIN_API_TOKEN="tu_token_seguro_de_administracion"

# Puerto y entorno
PORT=3000
NODE_ENV="production"
```

Estructura de persistencia dinámica en `config/admin-settings.json` :

```
{
  "provider": "openrouter",
  "preferredModel": "gemini-3.8-flash",
  "openaiApiKey": "sk-or-v1-xxxxxxxxxxxx",
  "openaiBaseUrl": "https://openrouter.ai/api/v1",
  "openaiModel": "anthropic/claude-3.7-sonnet",
  "customHeaders": {
    "HTTP-Referer": "https://aegisai.local",
    "X-Title": "AegisAI Compliance"
  },
  "temperature": 0.0,
  "maxTokens": 8192,
  "fallbackModel": "openai/gpt-4o-mini",
  "updatedAt": "2026-09-17T14:40:00.000Z"
}
```

3.3 Parámetros de Control y Gobernanza de Inferencia

1. **Temperatura:** Configurable de 0.0 a 1.0 (Predeterminado: `0.0` para garantizar evaluaciones normativas deterministas y científicamente reproducibles).
2. **Límite de Tokens de Salida (`maxTokens`):** Límite máximo de generación por bloque de evaluación (Predeterminado: `8192`).
3. **Modelo de Contingencia (`fallbackModel`):** Modelo secundario que asumirá la carga si el modelo principal sufre agotamiento temporal de cuota (HTTP 429/503).
4. **Cabeceras Personalizadas (`customHeaders`):** Objeto JSON para inyectar cabeceras corporativas, etiquetas de facturación o autenticación personalizada.

3.4 Diagnóstico de Conectividad en Tiempo Real y Hot-Reload

Desde la interfaz web de administración o mediante API REST, el administrador puede validar el canal de inferencia midiendo la **latencia en milisegundos (ms)**:

```
curl -X POST http://localhost:3000/api/admin/test-connection \
  -H "Content-Type: application/json" \
  -H "x-admin-token: TU_ADMIN_API_TOKEN" \
  -d '{"provider": "openrouter", "model": "anthropic/claude-3.7-sonnet"}'
```

Respuesta esperada:

```
{
  "ok": true,
  "provider": "openrouter",
  "latencyMs": 1150,
  "model": "anthropic/claude-3.7-sonnet",
  "message": "Conexión exitosa con OPENROUTER API",
  "sampleResponse": "OK"
}
```

Al guardar en la UI, los cambios se aplican de inmediato en caliente (**hot-reload**) sin requerir el reinicio del servidor Node.js ni del contenedor.

3.5 Batería de Pruebas Automatizada de Motores LLM

Para certificar la correcta operación de los proveedores:

```
npm run test:llm
```

Ejecuta 6 pruebas automatizadas: verificación del estado inicial, test en vivo con medición de latencia, configuración dinámica de OpenRouter/OpenAI, comprobación de persistencia con ofuscación de claves, tolerancia a fallos ante caídas de red y restauración determinista.

---

4. Gestión del Almacenamiento Dual y Persistencia

4.1 Arquitectura de Almacenamiento Dual

Para garantizar la inmunidad ante problemas de red o restricciones de reglas de seguridad en la nube, AegisAI implementa persistencia híbrida:

1. **Directorio Local JSON (`config/frameworks/*.json`):** Almacenamiento maestro en disco de las normativas ingeridas (LFPDPPP, LFPC, EU AI Act).
2. **Colección Cloud Firestore (`custom_frameworks` y `audits`):** Replicación en la nube para sincronización multi-instancia.

4.2 Respaldos del Catálogo de Marcos

Para realizar un respaldo preventivo de todas las leyes y políticas del módulo BYOF:

```
# Crear directorio de respaldo con fecha
mkdir -p /backups/aegisai/$(date +%Y%m%d)

# Copiar el directorio completo de configuraciones y marcos
cp -r /opt/aegisai/config/frameworks/*.json /backups/aegisai/$(date +%Y%m%d)/
```

4.3 Procedimiento para Eliminar un Marco Normativo

Para dar de baja una regulación en desuso:

```
curl -X DELETE http://localhost:3000/api/frameworks/fw-id-a-eliminar \
  -H "x-admin-token: TU_ADMIN_API_TOKEN"
```

El sistema eliminará el archivo JSON local y removerá el documento correspondiente en Cloud Firestore.

---

5. Telemetría, Logs y Observabilidad

5.1 Registro de Métricas por Auditoría

Cada auditoría procesada registra formalmente en su documento de base de datos los siguientes atributos de telemetría de IA:

- `modelUsed` : Modelo exacto de Gemini que generó el dictamen (ej. `gemini-3.1-flash-lite`).
- `latencyMs` : Tiempo de respuesta total del motor en milisegundos.

- `promptTokens`: Total de tokens consumidos en las especificaciones de entrada.
- `completionTokens`: Total de tokens generados en los análisis y recetas de mitigación.

5.2 Sanitización y Blindaje de Logs

El servidor cuenta con filtros de supresión que garantizan que ninguna clave de API (`AIzaSy...`), token administrativo ni información sensible de clientes aparezca en los logs de consola o transportadores de eventos.

5.3 Monitoreo de Salud de la Aplicación

Endpoint de sondeo para balanceadores de carga y sondas de Kubernetes (Liveness / Readiness Probes):

```
curl -I http://localhost:3000/api/health
# Respuesta: HTTP/1.1 200 OK -> {"status":"ok"}
```

---

6. Procedimientos Operativos Estándar (SOPs)

SOP-01: Rotación de Clave de API de Google Gemini

1. Genere una nueva clave de API en la consola de Google Cloud / Google AI Studio.
2. Edite el archivo `.env` en el servidor:

   ```
   nano .env
   # Actualice la variable GEMINI_API_KEY="NUEVA_CLAVE"
   ```

3. Reinicie el servicio de AegisAI:

   ```
   systemctl restart aegisai
   ```

4. Ejecute el test de conectividad para verificar el correcto funcionamiento:

   ```
   curl -X POST http://localhost:3000/api/admin/test-connection -H "x-admin-token: TU_TOKEN"
   ```

SOP-02: Respuesta ante Incidente de Cuota Excedida (HTTP 429)

1. Verifique el consumo en la consola de Google Cloud APIs & Services.
2. Si el proyecto tiene límites de cuota por minuto (RPM) reducidos, configure en `.env` o en la vista de administración el modelo alternativo `gemini-3.1-flash-lite`, el cual cuenta con los límites más amplios y menor costo por token.
3. Solicite un incremento de cuota (Quota Increase Request) en Google Cloud Console para la API de Gemini v1beta.